SOC INCIDENT REPORT • THREAT HUNT

Adversary-in-the-Middle Attack

AiTM • Session Hijacking • MFA Bypass • BEC Fraud • Infostealer

ATTRIBUTED THREAT ACTOR

Scattered Spider

UNC3944 • Octo Tempest • 0ktapus

Log(N) Pacific Cyber Range • LAW-Cyber-Range • Microsoft Sentinel • KQL

Detection: 2026-02-25 • Report: 2026-04-17 • Classification: CONFIDENTIAL

ANALYST

Vishvdeep Bal

vishvdeepbal.infosec@gmail.com • SOC Tier 2 • Log(N) Pacific • 2410 pts • 71st Place

Case ID: IR-2026-0225-001 • CRITICAL • CONTAINED • 28/29 Challenges Solved

1. Executive Summary

On February 25, 2026, SOC Analyst Vishvdeep Bal conducted a structured threat hunt on the Log(N) Pacific Cyber Range, identifying and fully reconstructing a sophisticated Adversary-in-the-Middle (AiTM) attack against the Microsoft 365 account of m.smith@lognpacific.org. The intrusion was attributed to Scattered Spider (UNC3944 / Octo Tempest), a financially motivated threat group previously linked to breaches at MGM Resorts and Caesars Entertainment, known for Infostealer credential harvesting, MFA fatigue push harassment, AiTM reverse-proxy phishing, and Business Email Compromise fraud.

The attacker obtained Mark Smith's credentials via Infostealer malware, then used a reverse-proxy phishing framework (consistent with Evilginx) to intercept his session token mid-authentication, fully bypassing MFA. Operating from 205.147.16.190 (Netherlands) on a Linux/Firefox 147.0 platform, the attacker achieved account takeover at 21:59:52 UTC after 3 pre-success attempts. They then executed a multi-stage post-compromise campaign: automated Outlook and SharePoint data access; creation of two covert inbox rules (rule '.' forwarding financial emails to insights@duck.com, rule '..' deleting security alerts with StopProcessingRules:True); file access across OneDrive for Business and SharePoint Online; and a Business Email Compromise wire fraud attempt targeting j.reynolds@lognpacific.org via email thread hijacking.

The critical defensive gap: ConditionalAccessStatus was notApplied on every attacker sign-in. All activity was forensically correlated through a single AAD Session ID (00225cfa-a0ff-fb46-a079-5d152fcdf72a). 28 of 29 challenges were solved, scoring 2410 points and placing 71st globally on the Log(N) Pacific leaderboard.

Case Metadata

Case ID	IR-2026-0225-001
Incident Date	February 25, 2026
Report Date	April 17, 2026
Analyst	Vishvdeep Bal
Analyst Email	vishvdeepbal.infosec@gmail.com
Organisation	Log(N) Pacific Cyber Range
Victim Account	m.smith@lognpacific.org (Mark Smith)
Victim IP / Device	172.175.65.103 — Windows 10 / Edge 145.0
Attacker IP	205.147.16.190 — Netherlands (NE)
Attacker OS/Browser	Linux / Firefox 147.0 — unmanaged, non-compliant
AAD Session ID	00225cfa-a0ff-fb46-a079-5d152fcdf72a
BEC Target	j.reynolds@lognpacific.org (Jay Reynolds)
Exfil Address	insights@duck.com (attacker-controlled)
Attack Type	AiTM • Session Hijacking • MFA Bypass • BEC • Infostealer
Attributed Actor	Scattered Spider (UNC3944 / Octo Tempest / 0ktapus)
Severity	CRITICAL
Conditional Access Gap	notApplied — No CA policies enforced on any attacker sign-in
Hunt Score	2410 pts • 71st Place • 28/29 Challenges Solved

2. Threat Actor — Scattered Spider

Challenge Q29 confirmed attribution to Scattered Spider (also tracked as UNC3944, Octo Tempest, and 0ktapus). The group is primarily English-speaking and financially motivated, specialising in MFA fatigue, AiTM phishing, SIM swapping, and large-scale BEC fraud. Their documented victims include MGM Resorts International and Caesars Entertainment, both compromised using techniques observed here: MFA fatigue push attacks, reverse-proxy session token theft, and inbox rule persistence.

Figure 1 — Q29: Threat Actor Attribution — Scattered Spider — Correct (Log(N) Pacific Cyber Range)

Scattered Spider TTPs Confirmed in This Investigation

TTP	Evidence Observed	MITRE ID
Infostealer credential theft	Mark's credentials pre-obtained before MFA fatigue (Q27: Infostealer)	T1555
AiTM reverse-proxy phishing	Evilginx-style session token intercept from NL IP	T1557.001
MFA Fatigue (push harassment)	3 pre-success MFA attempts (50074, 50140×2) — T1621 confirmed Q25	T1621
Anonymising infrastructure	205.147.16.190 Netherlands proxy —	T1090

TTP	Evidence Observed	MITRE ID
	geolocation NE	
Linux/Firefox operator profile	DeviceDetail: Linux, Firefox 147.0, isCompliant:false	T1078
Inbox rule forward (stealth)	Rule '.' — ForwardTo: insights@duck.com, financial keywords	T1137.005
Inbox rule delete (blindfold)	Rule '..' — deletes security/phishing/compromised alerts	T1137.005
StopProcessingRules priority	Both rules set StopProcessingRules:True — suppress user rules	T1137.005
Email thread hijacking BEC	RE: Invoice #INV-2026-0892 wire fraud to j.reynolds	T1566.002
OneDrive/SharePoint exfil	FileAccessed, PageViewed, ListCreated from 205.147.16.190	T1213.002

3. Technologies & Tools Used

Category	Technology	Purpose
SIEM	**Microsoft Sentinel**	Primary investigation platform — log ingestion, querying, alerting
Query Language	**KQL (Kusto Query Language)**	All detection, correlation, and behavioural analysis queries
Log Source	**Azure AD SigninLogs**	Auth telemetry — IP, ResultType, ConditionalAccessStatus, SessionId
Log Source	**CloudAppEvents**	Post-auth actions — MailItemsAccessed, New-InboxRule, FileAccessed
Log Source	**EmailEvents**	Email metadata — BEC detection, thread hijacking, SenderIPv4
Identity Platform	**Microsoft Entra ID (Azure AD)**	MFA config, Conditional Access, session management
Productivity Suite	**Microsoft 365**	Target — Outlook, SharePoint Online, OneDrive for Business
Workspace	**LAW-Cyber-Range**	Log Analytics Workspace — cyber range data source
Threat Framework	**MITRE ATT&CK v14**	Tactic/technique mapping across full kill chain
Cyber Range	**Log(N) Pacific**	Simulated enterprise SOC environment for the hunt
Attack Tooling	**Evilginx / AiTM Proxy**	Suspected reverse-proxy session token theft framework
Cred Source	**Infostealer Malware**	Initial credential acquisition — saved passwords/browser data

4. Indicators of Compromise

Attacker IP	205.147.16.190 (Netherlands)
Attacker OS/Browser	Linux / Firefox 147.0 (unmanaged, isCompliant:false, isManaged:false)
Victim Account	m.smith@lognpacific.org (Mark Smith)
Victim IP/Device	172.175.65.103 — Windows 10 / Edge 145.0
AAD Session ID	00225cfa-a0ff-fb46-a079-5d152fcdf72a
Forward Rule Name	. (single period) — stealth naming
Forward Destination	insights@duck.com (attacker-controlled exfil)
Forward Keywords	invoice, payment, wire, transfer
Delete Rule Name	.. (double period)
Delete Keywords	suspicious, security, phishing, unusual, compromised, verify
Rule Processing Flag	StopProcessingRules: True on both rules
BEC Target	j.reynolds@lognpacific.org (Jay Reynolds, Finance)
BEC Subject	RE: Invoice #INV-2026-0892 — Updated Banking Details (thread hijack)
BEC Email Direction	Intra-org — bypassed external email gateway
BEC Sender IP	205.147.16.190 — same as sign-in IP (cross-correlated)
Cloud Storage	Microsoft OneDrive for Business — FileAccessed 22:07:16 UTC
Cloud Storage	Microsoft SharePoint Online — PageViewed, ListCreated, SignInEvent
CA Gap	ConditionalAccessStatus: notApplied on ALL attacker sign-ins
Cred Source	Infostealer malware — harvested before MFA fatigue phase

5. Full Attack Timeline

Timestamp (UTC)	Event	Result	Source IP
Pre-incident	Infostealer harvests Mark's M365 credentials	Cred theft	—
21:44:11	Mark signs in legitimately	0 — Success	172.175.65.103
21:44:23	KMSI interrupt — session token interception window	50140 (KMSI)	172.175.65.103
21:54:24	Attacker: MFA gate hit (attempt 1)	50074 (MFA)	205.147.16.190
21:54:55	Session suspended — KMSI interrupt (attempt 2)	50140 (KMSI)	205.147.16.190

Timestamp (UTC)	Event	Result	Source IP
21:55:15	Final KMSI re-attempt (attempt 3)	50140 (KMSI)	205.147.16.190
21:59:52	PIVOT: MFA bypassed via token replay — first success	0 — Success	205.147.16.190
21:56–22:05	MailItemsAccessed — inbox read to profile target	CloudAppEvent	205.147.16.190
22:02:33	Inbox rule '.' created — ForwardTo insights@duck.com	New-InboxRule	205.147.16.190
22:03:59	Inbox rule '..' created — DeleteMessage security terms	New-InboxRule	205.147.16.190
22:06:39	BEC sent as Mark: RE: Invoice #INV-2026-0892 (thread hijack)	EmailSent	205.147.16.190
22:07:16	FileAccessed — Microsoft OneDrive for Business	FileAccessed	205.147.16.190
22:07:47	PageViewed — Microsoft SharePoint Online	PageViewed	205.147.16.190
22:07–22:10	ListCreated, ListColumnCreated, Broke sharing inheritance	CloudAppEvents	205.147.16.190
22:29:33	Urgent Wire Transfer Request sent to j.reynolds	EmailSent	205.147.16.190
22:31:19.668	Millisecond-identical burst — automated exfil active	0 — Success	205.147.16.190

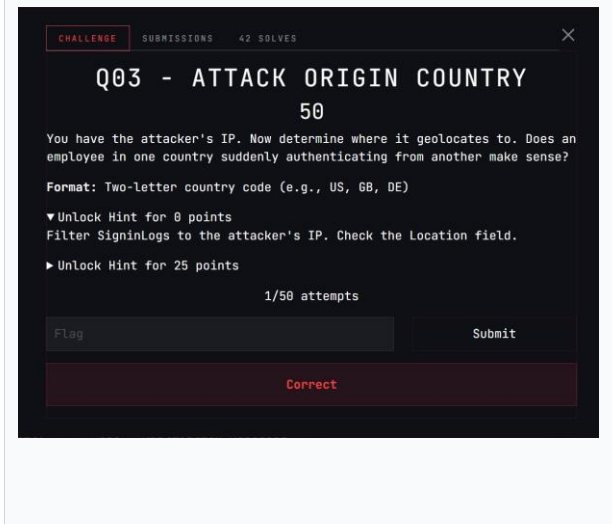
6. Hunt Challenge Evidence — Log(N) Pacific Cyber Range

All 28 challenges below were solved by Vishvdeep Bal using KQL against the LAW-Cyber-Range Log Analytics Workspace in Microsoft Sentinel. Each entry pairs the challenge question screenshot with the corresponding live workspace query and result.

Figure 2 — Scoreboard: Vishvdeep Bal • 2410 pts • 71st Place — Log(N) Pacific Cyber Range

Q02 — Attacker Source IP (50 pts) & Q03 — Attack Origin Country (50 pts)

Q02: Baselining Mark's daytime IP (172.175.65.103) against evening sessions revealed 205.147.16.190 as the anomalous IP. Q03: Location field confirmed country code NE — Netherlands.



Q02 — Attacker Source IP: Correct | Q03 — Origin Country NE: Correct

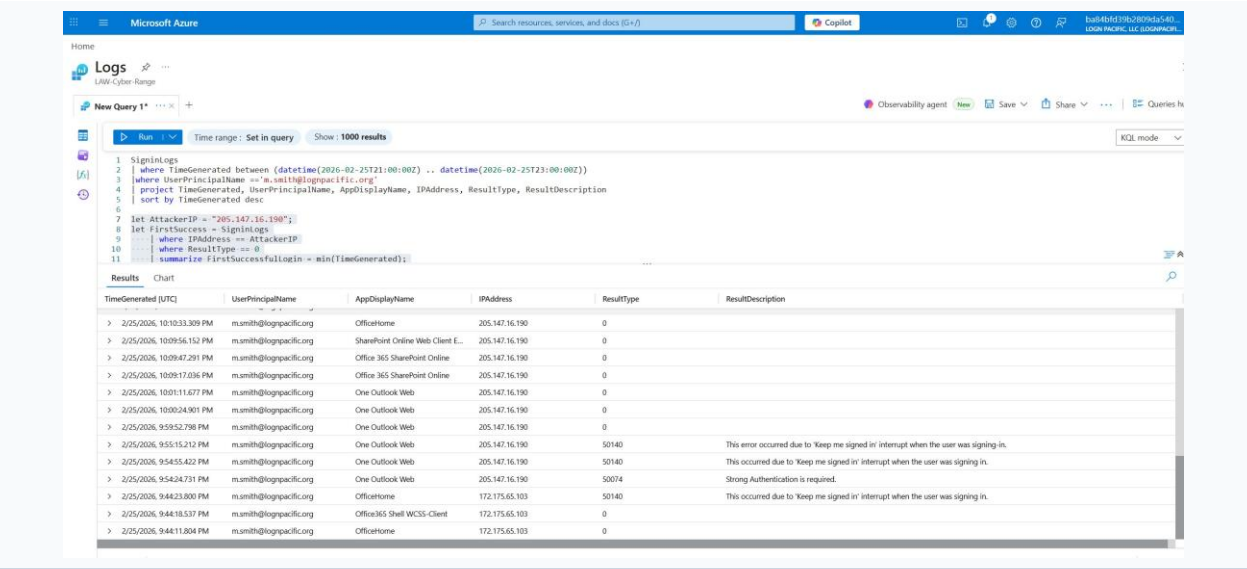
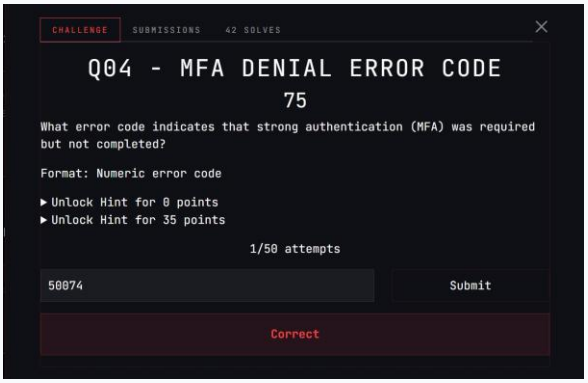


Figure 3 — LAW-Cyber-Range: SigninLogs query — both IPs, ResultTypes, AppDisplayNames visible

Q04 — MFA Denial Error Code (75 pts) & Q05 — MFA Fatigue Intensity (75 pts)

Q04: ResultType 50074 confirmed the attacker hit the MFA gate. Q05: KQL count of pre-success non-zero entries returned exactly 3 (50074, 50140, 50140).



Q04 — MFA Code 50074: Correct | Q05 — Fatigue Count 3: Correct

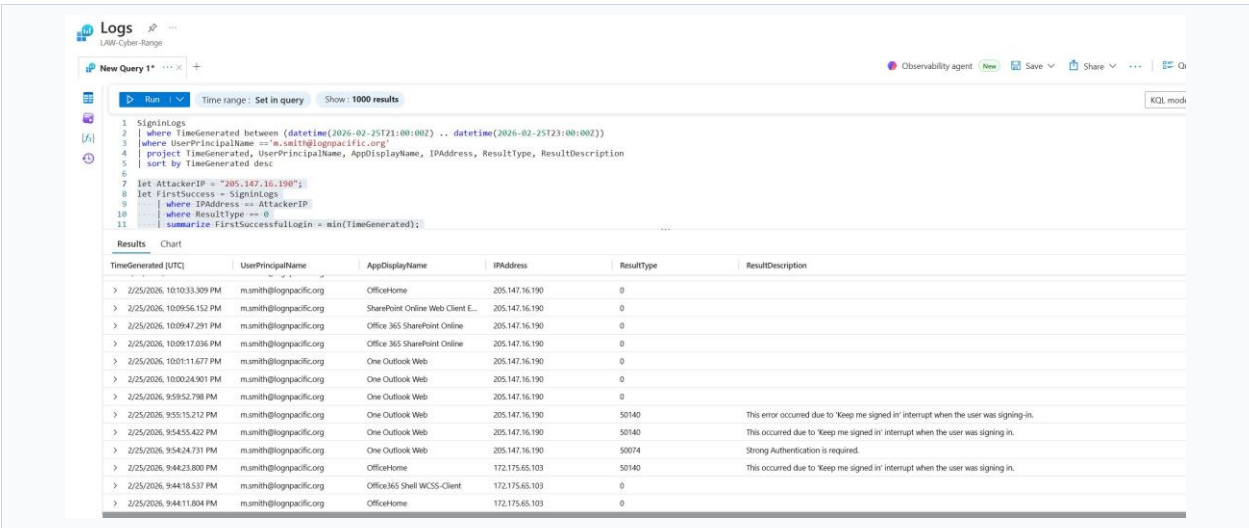
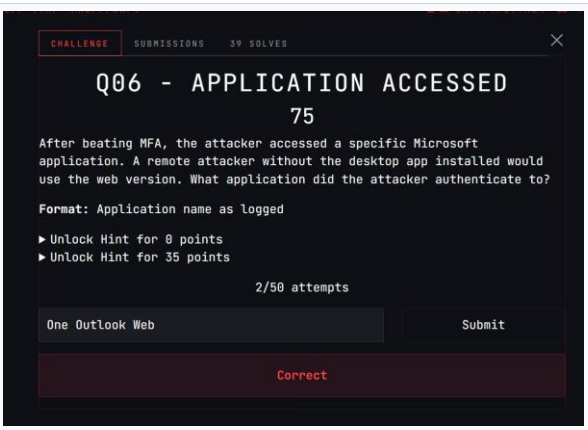


Figure 4 — LAW-Cyber-Range: SigninLogs with full query set including pre-success count

Q06 — Application Accessed (75 pts) & Q07 — Attacker Operating System (75 pts)

Q06: First post-MFA application was 'One Outlook Web'. Q07: DeviceDetail JSON confirmed Linux OS — vs Mark's Windows 10 baseline.



Q06 — App: One Outlook Web: Correct | Q07 — OS: Linux: Correct

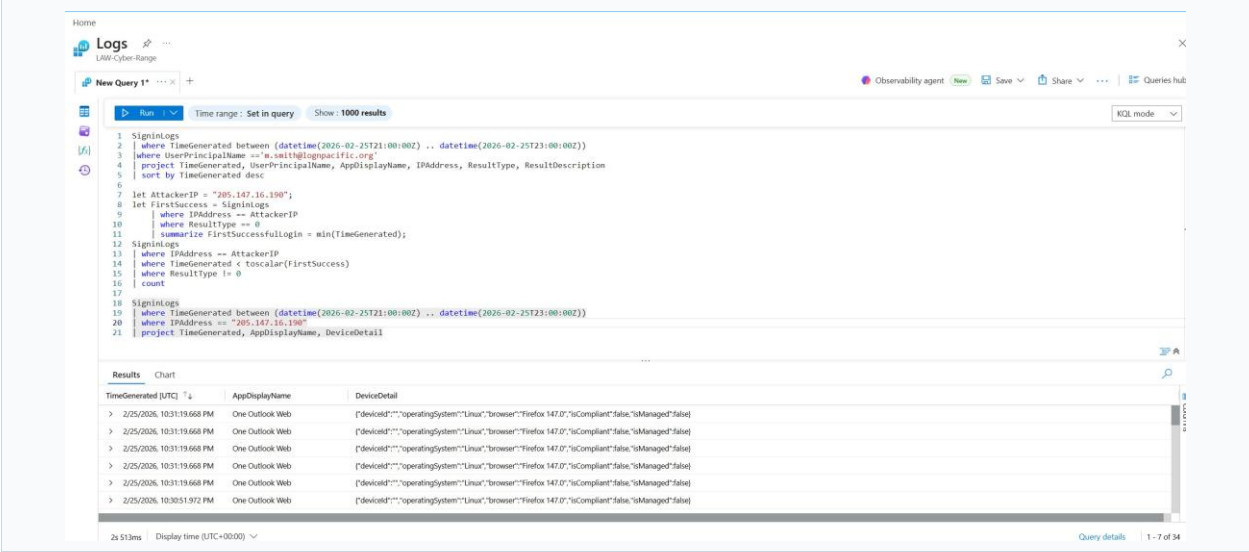


Figure 5 — LAW-Cyber-Range: DeviceDetail attacker query — Linux, Firefox 147.0, isCompliant:false, isManaged:false

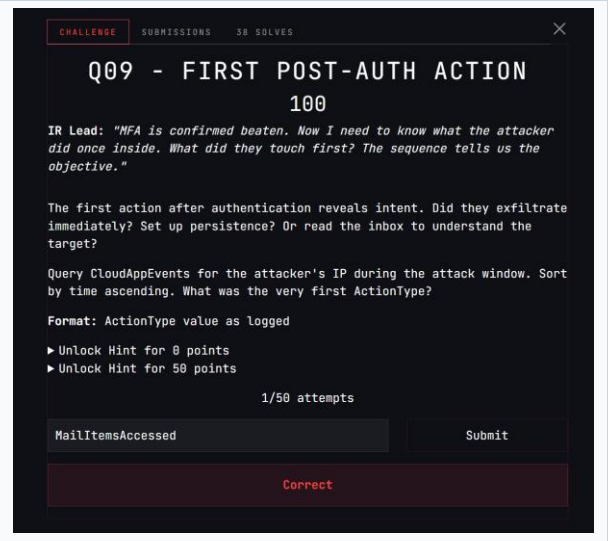
Q08 — Attacker Browser (75 pts)

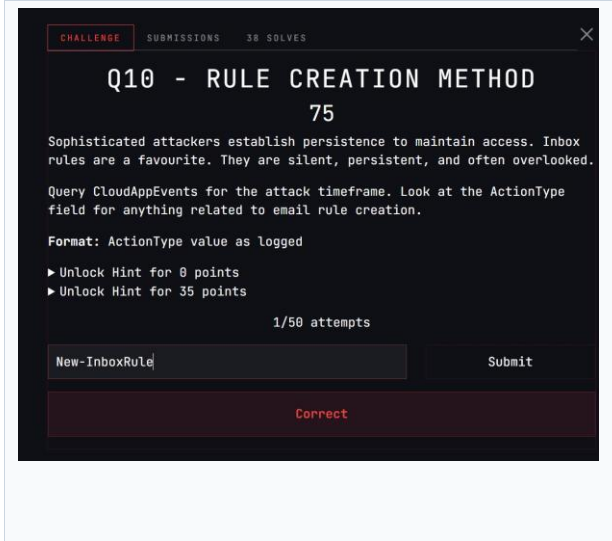
DeviceDetail browser field confirmed Firefox 147.0 — 3 anomaly layers: different country + different OS + different browser from Mark's Edge 145.0 baseline.

Figure 6 — Q08: Attacker Browser Firefox 147.0 — Correct (Log(N) Pacific)

Q09 — First Post-Auth Action (100 pts) & Q10 — Rule Creation Method (75 pts)

Q09: CloudAppEvents sorted ascending — MailItemsAccessed was the very first post-auth action. The attacker read the inbox to profile the target before setting up persistence. Q10: ActionType New-InboxRule confirmed the persistence mechanism.





Q09 — First Action: MailItemsAccessed: Correct | Q10 — Method: New-InboxRule: Correct

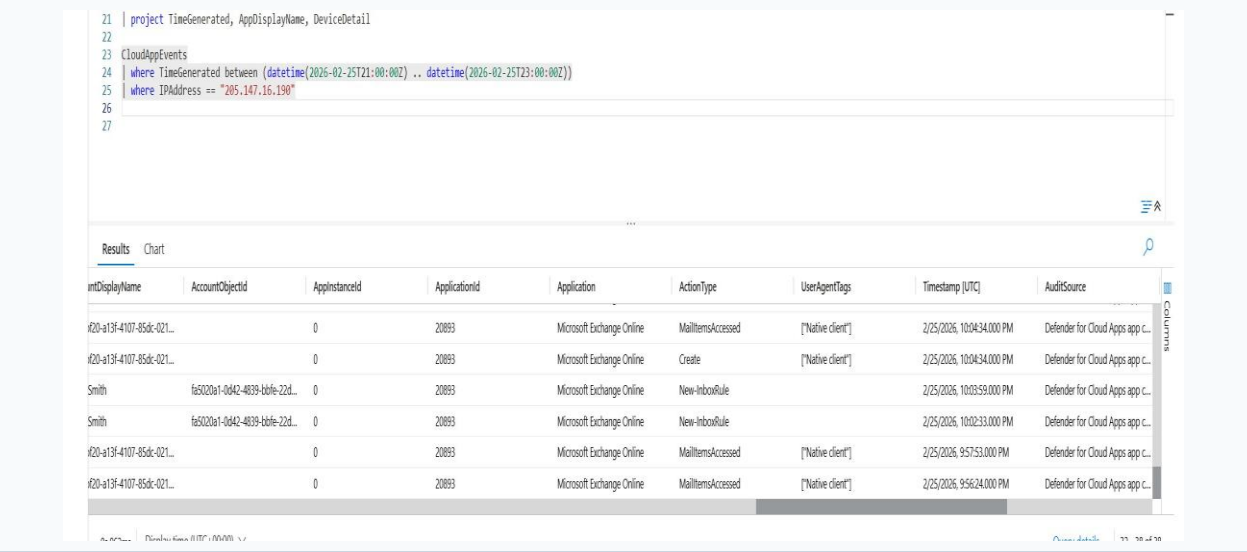
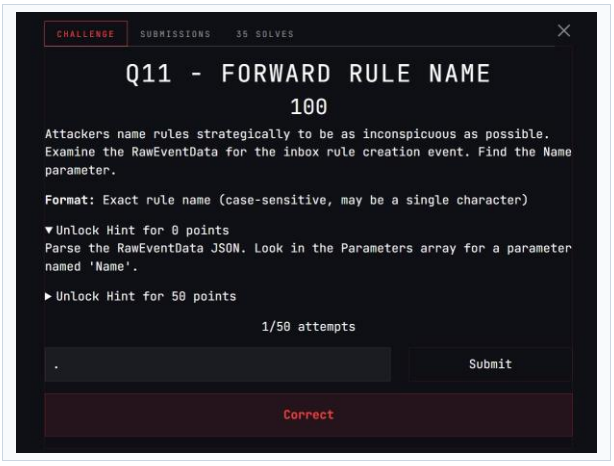
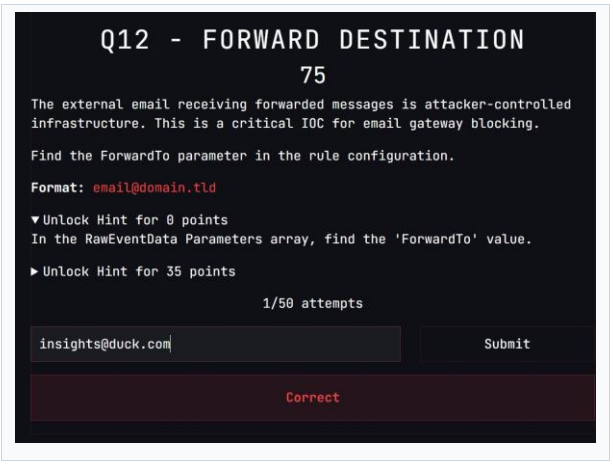


Figure 7 — LAW-Cyber-Range: CloudAppEvents showing MailItemsAccessed, Create, and New-InboxRule actions

Q11 — Forward Rule Name (100 pts) & Q12 — Forward Destination (75 pts)

Q11: RawEventData Parameters Name field revealed '.' (single period) — nearly invisible in any inbox rules UI. Q12: ForwardTo parameter contained insights@duck.com — attacker's exfil address for financial emails.





Q11 — Rule Name '.': Correct | Q12 — ForwardTo: insights@duck.com: Correct

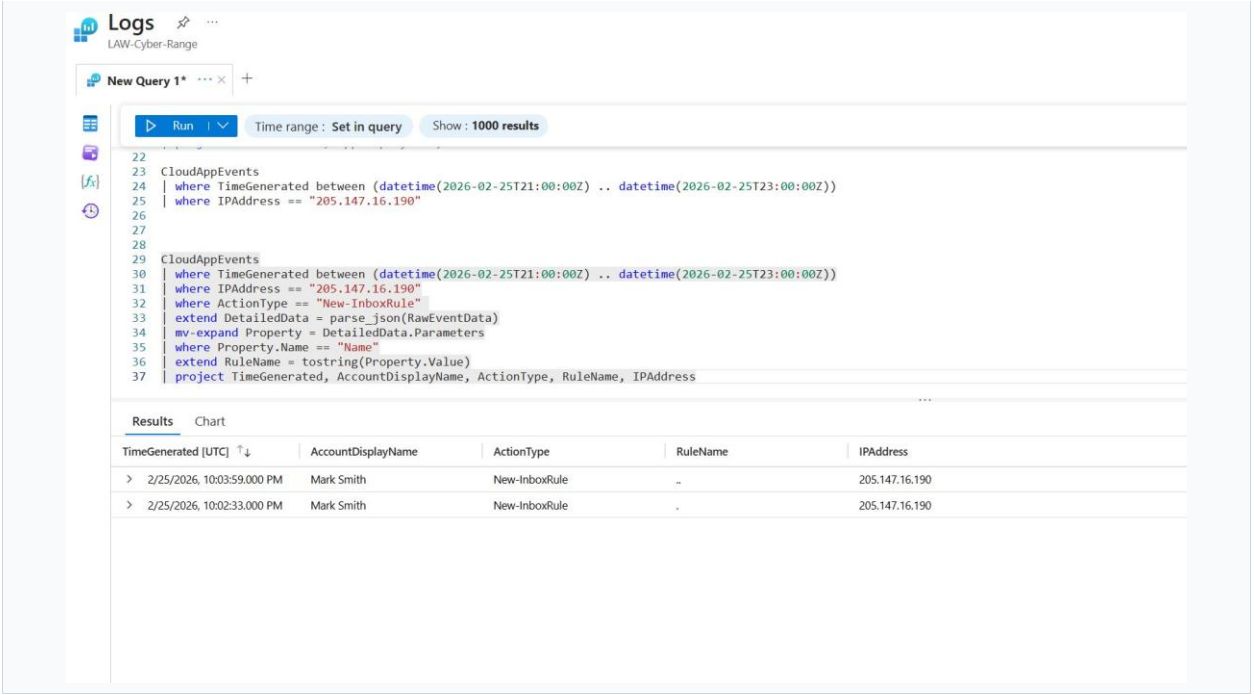


Figure 8 — LAW-Cyber-Range: New-InboxRule query showing both rules '.' and '..' with RawEventData

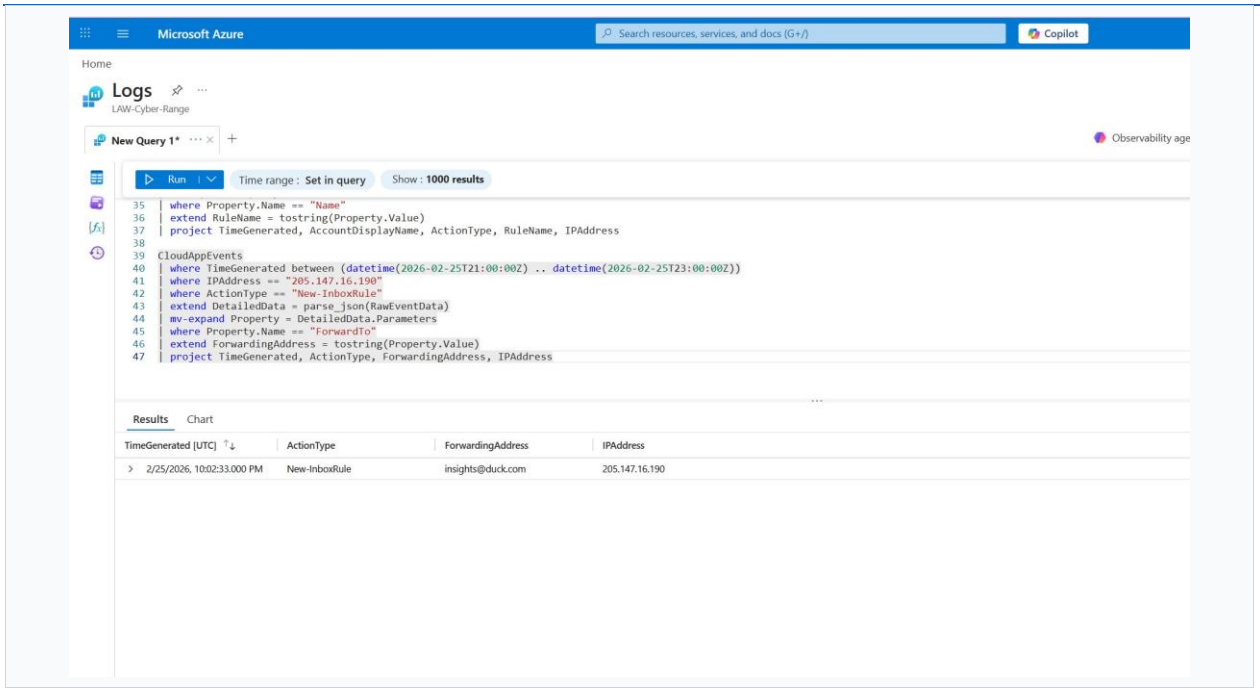
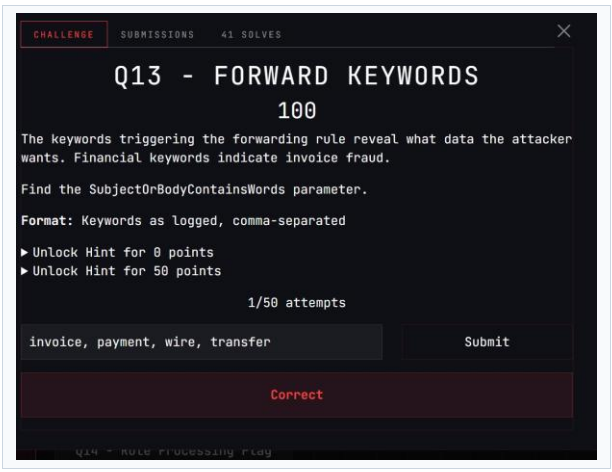
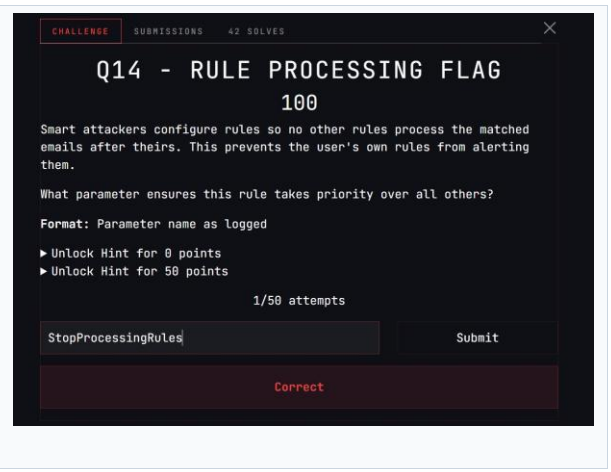


Figure 9 — LAW-Cyber-Range: ForwardTo parameter — insights@duck.com at 22:02:33 UTC from 205.147.16.190

Q13 — Forward Keywords (100 pts) & Q14 — Rule Processing Flag (100 pts)

Q13: SubjectOrBodyContainsWords on rule '.' = invoice, payment, wire, transfer — confirming BEC/invoice fraud intent. Q14: StopProcessingRules:True on both rules prevents Mark's own alert rules from ever firing.





Q13 — Keywords: invoice, payment, wire, transfer: Correct | Q14 — StopProcessingRules: Correct

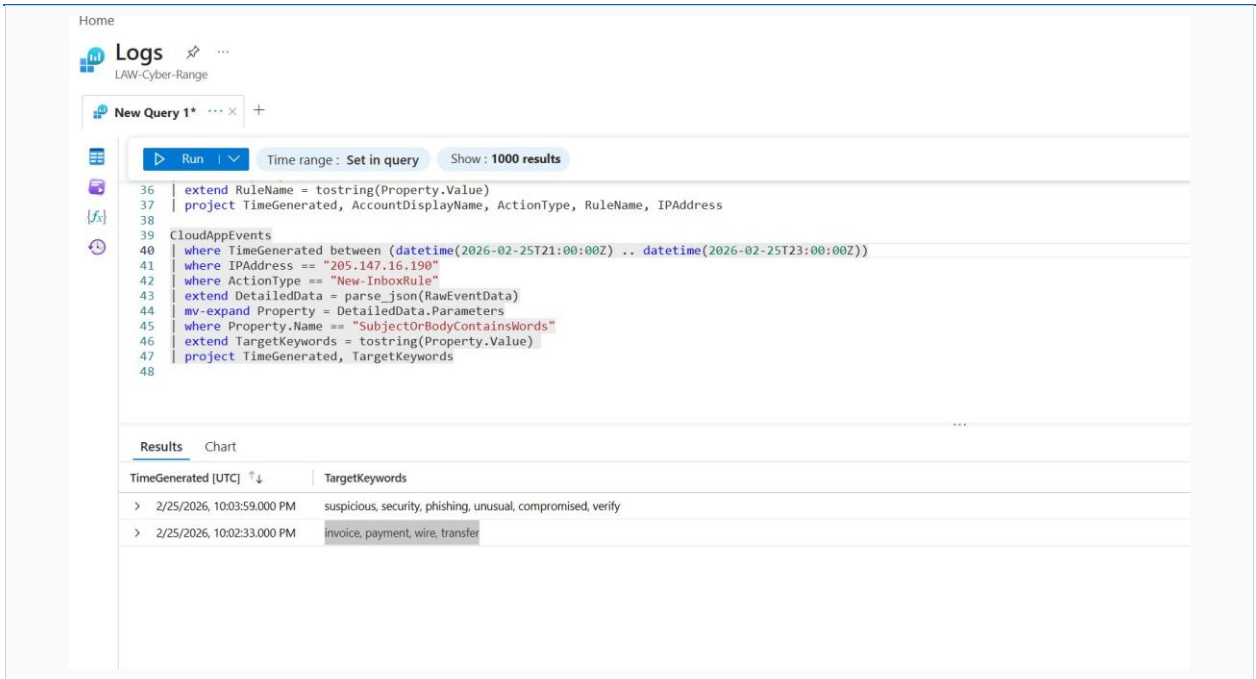
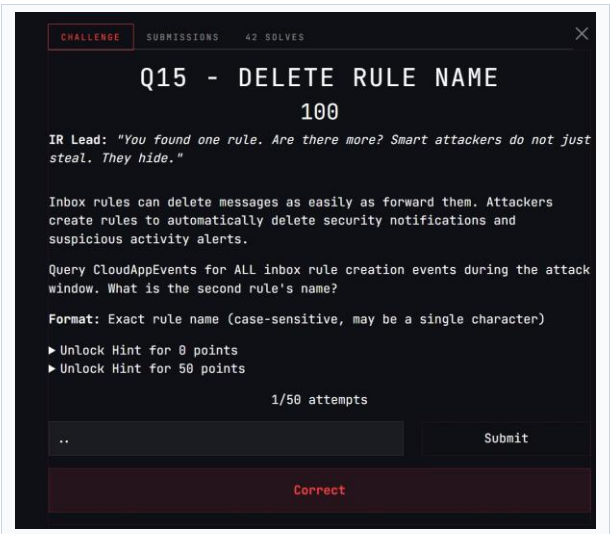
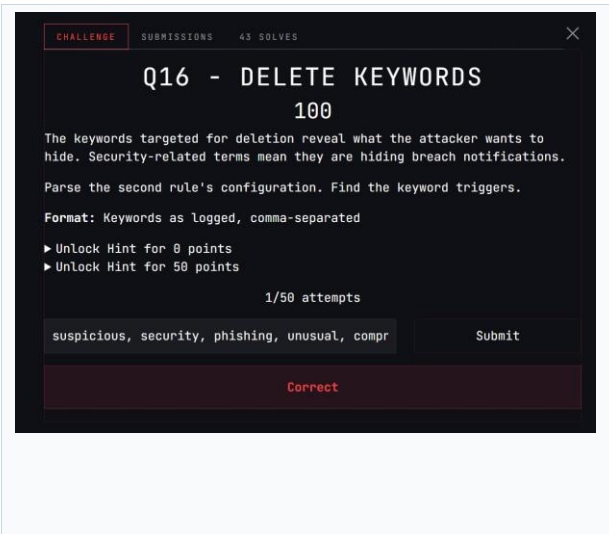


Figure 10 — LAW-Cyber-Range: SubjectOrBodyContainsWords — both rules' keyword sets revealed

Q15 — Delete Rule Name (100 pts) & Q16 — Delete Keywords (100 pts)

Q15: Second inbox rule named '..' (double period) — for deletion. Q16: Keywords: suspicious, security, phishing, unusual, compromised, verify — a complete security blackout ensuring no Microsoft alert or SOC notification ever reaches Mark.





Q15 — Delete Rule Name '..': Correct | Q16 — Delete Keywords: Correct

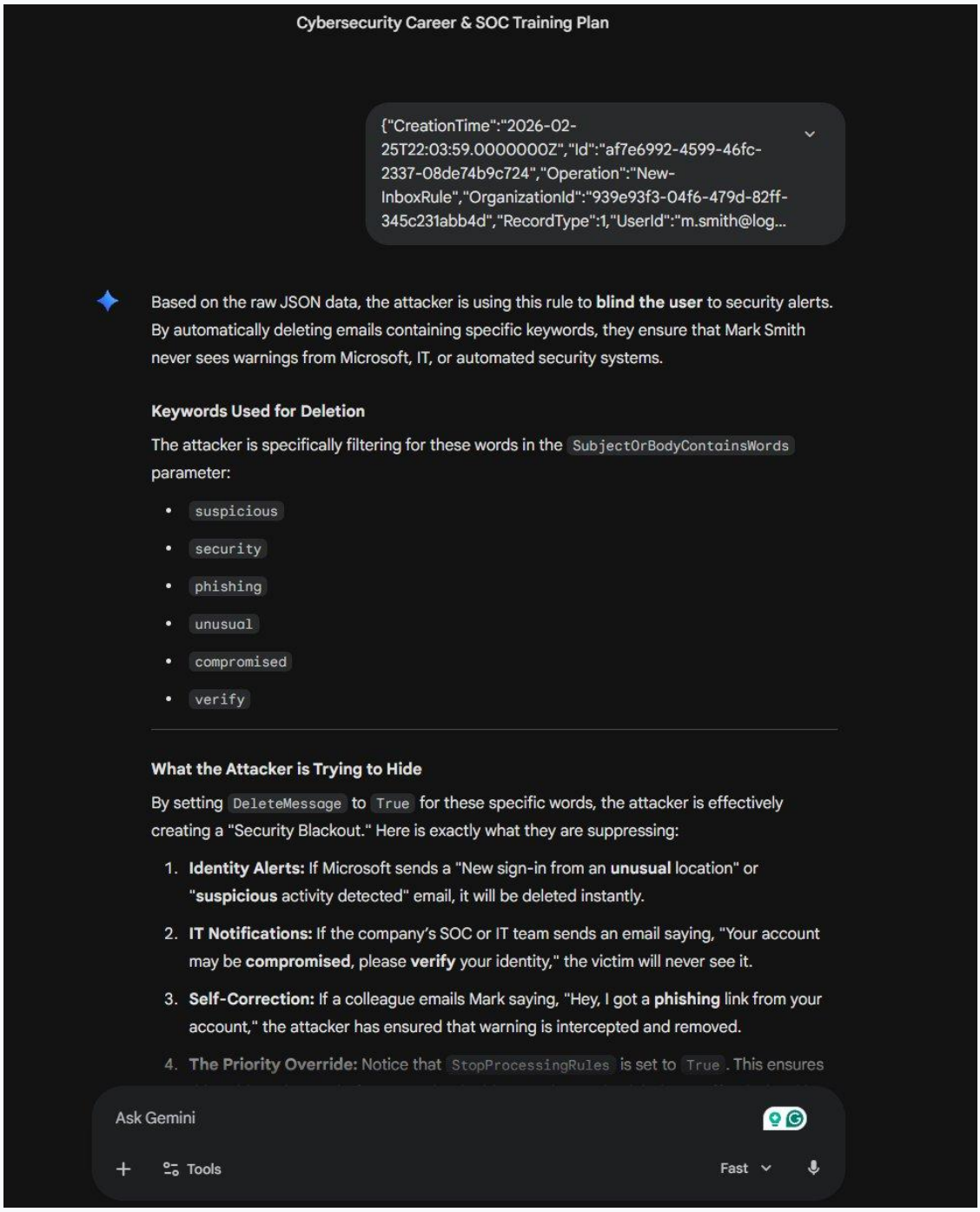
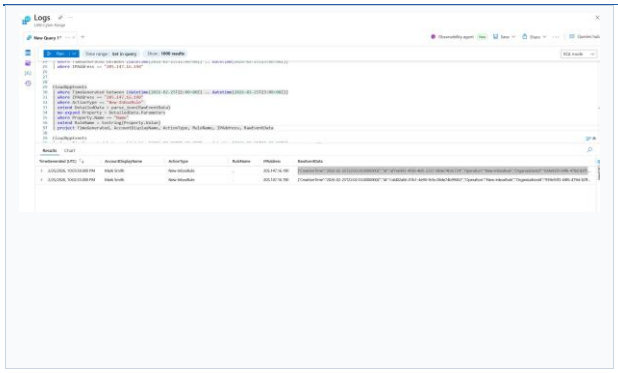
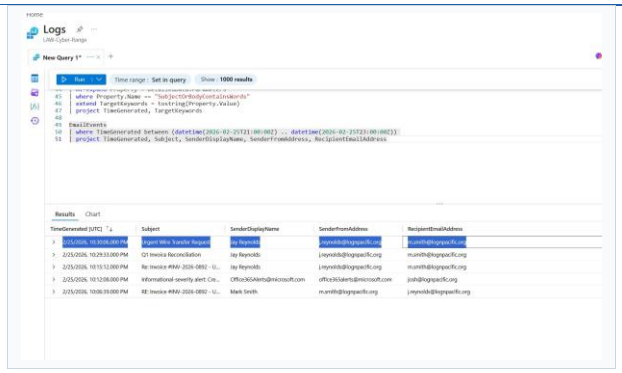


Figure 11 — LAW-Cyber-Range: RawEventData showing both inbox rules with full JSON parameters

Q17 — BEC Target (75 pts) & Q18 — BEC Subject Line (75 pts)

Q17: EmailEvents pivoted to the attacker IP revealed j.reynolds@lognpacific.org as the BEC target. Q18: The attacker used thread hijacking — replying to an existing invoice thread — maximising credibility. Subject: RE: Invoice #INV-2026-0892 - Updated Banking Details.



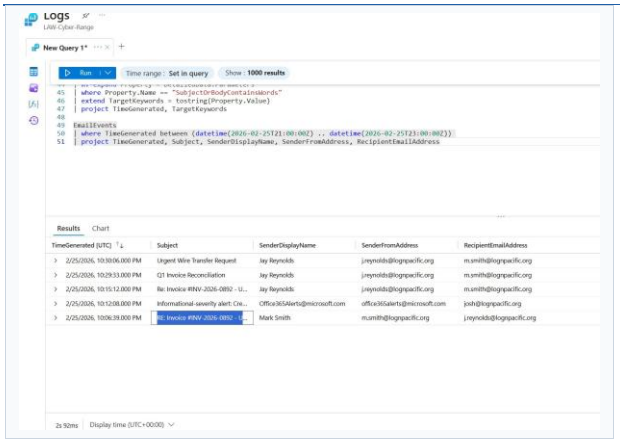


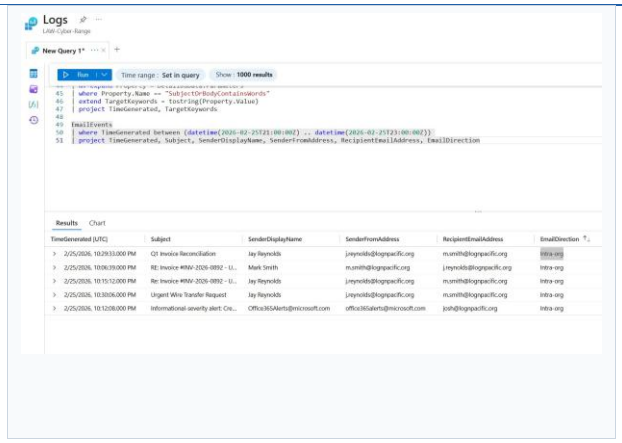
Q17 — BEC Target: j.reynolds: Correct | Q18 — BEC Subject: RE: Invoice #INV-2026-0892: Correct

Figure 12 — LAW-Cyber-Range: EmailEvents showing full email thread, subjects, senders, and recipients

Q19 — Email Direction (75 pts) & Q20 — BEC Sender IP (75 pts)

Q19: EmailDirection = Intra-org — the BEC email was internal, bypassing all external email gateway filters. Q20: SenderIPv4 = 205.147.16.190 — cross-referencing the sign-in IP proves the same stolen session sent the BEC email.



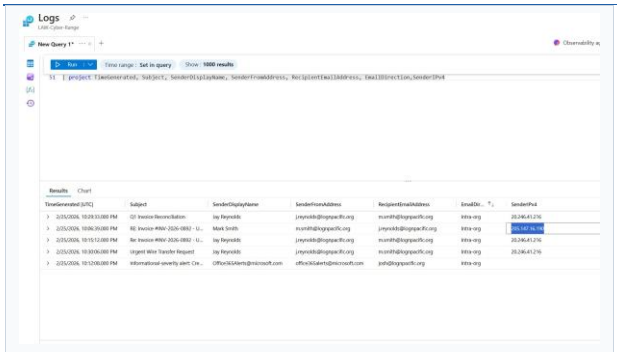


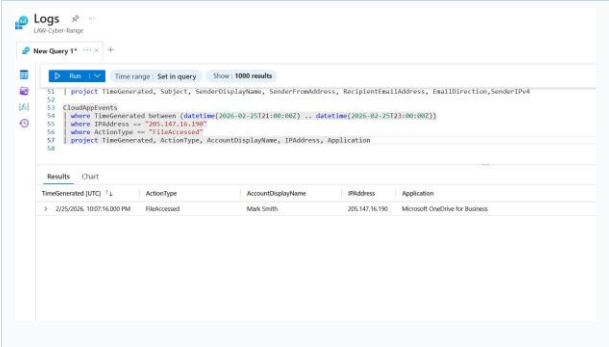
Q19 — Direction: Intra-org: Correct | Q20 — Sender IP: 205.147.16.190: Correct

Figure 13 — LAW-Cyber-Range: EmailEvents with SenderIPv4 — 205.147.16.190 sent the BEC email

Q21 — Cloud App Accessed (75 pts) & Q22 — SharePoint App Accessed (75 pts)

Q21: CloudAppEvents FileAccessed action confirmed Microsoft OneDrive for Business. Q22: SigninLogs confirmed Microsoft SharePoint Online. Data exposure spans both personal cloud storage and corporate file shares.





Q21 — OneDrive for Business: Correct | Q22 — SharePoint Online: Correct

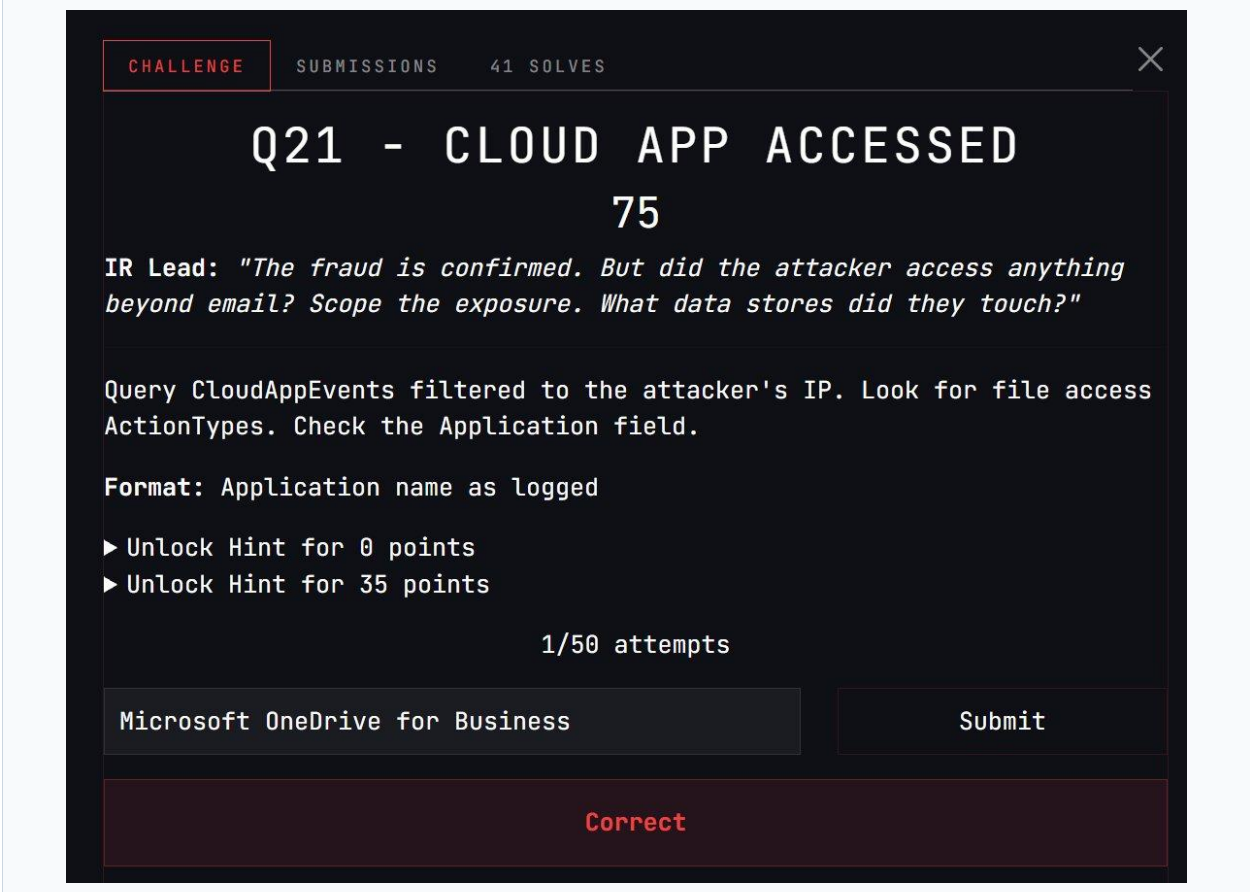
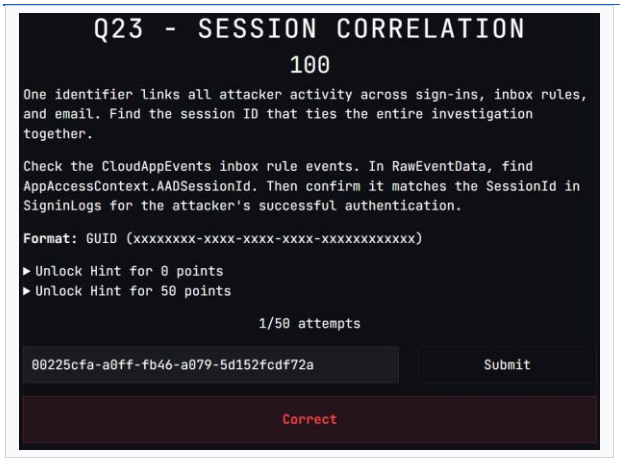
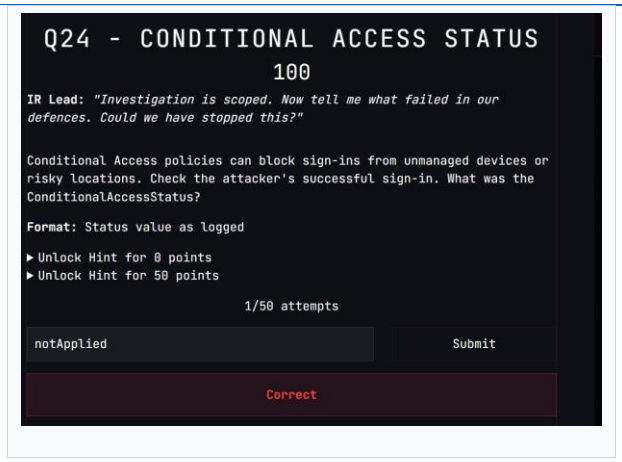


Figure 14 — LAW-Cyber-Range: CloudAppEvents — FileAccessed/PageViewed across OneDrive and SharePoint from attacker IP

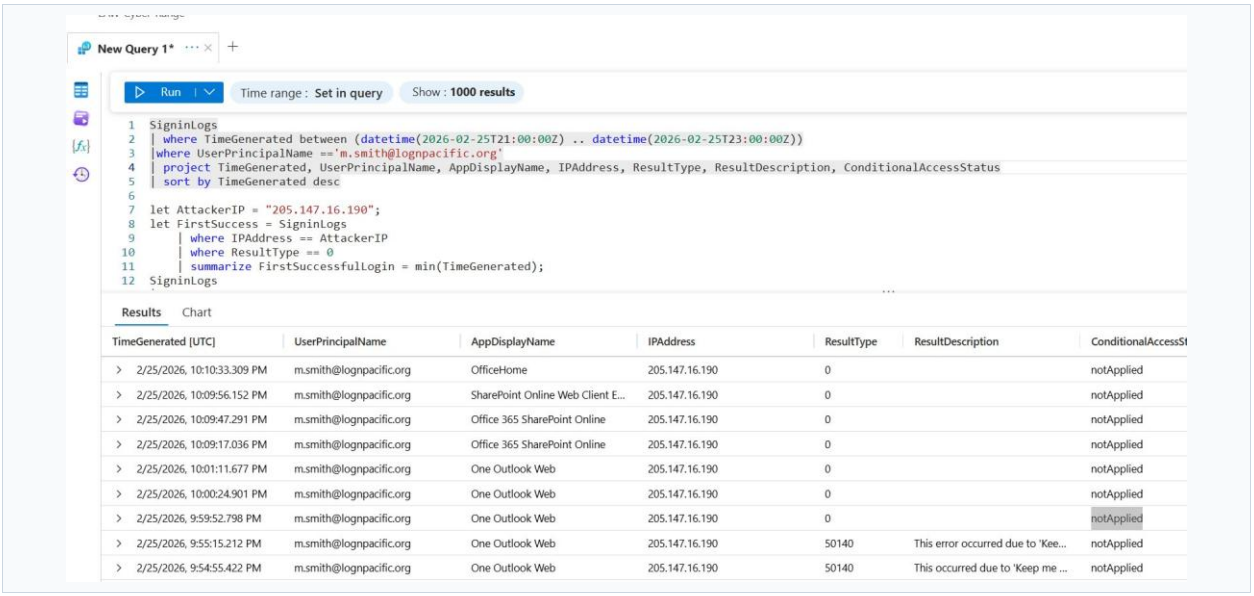
Q23 — Session Correlation (100 pts) & Q24 — Conditional Access Status (100 pts)

Q23: AppAccessContext.AADSessionId in inbox rule RawEventData cross-referenced with SigninLogs SessionId — single session ID ties all attacker activity. Q24: ConditionalAccessStatus = notApplied on every attacker sign-in — this is the critical defensive gap that enabled the entire attack.





Q23 — Session ID: 00225cfa...: Correct | Q24 — CA Status: notApplied: Correct

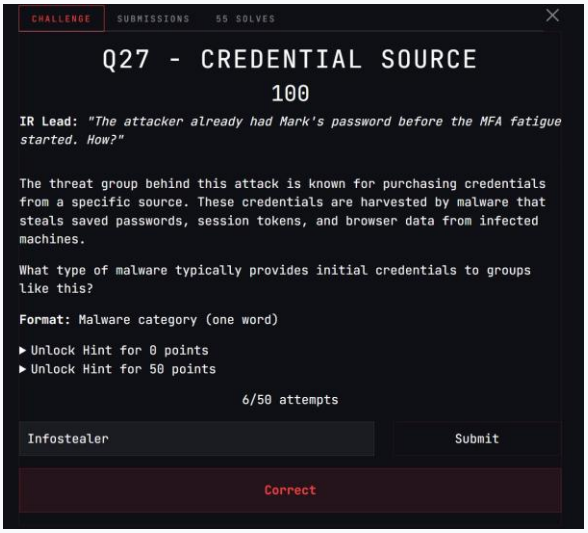


TimeGenerated [UTC]	UserPrincipalName	AppDisplayName	IPAddress	ResultType	ResultDescription	ConditionalAccessSt
2/25/2026, 10:10:33.309 PM	m.smith@lognpacific.org	OfficeHome	205.147.16.190	0		notApplied
2/25/2026, 10:09:56.152 PM	m.smith@lognpacific.org	SharePoint Online Web Client E...	205.147.16.190	0		notApplied
2/25/2026, 10:09:47.291 PM	m.smith@lognpacific.org	Office 365 SharePoint Online	205.147.16.190	0		notApplied
2/25/2026, 10:09:17.036 PM	m.smith@lognpacific.org	Office 365 SharePoint Online	205.147.16.190	0		notApplied
2/25/2026, 10:01:11.677 PM	m.smith@lognpacific.org	One Outlook Web	205.147.16.190	0		notApplied
2/25/2026, 10:00:24.901 PM	m.smith@lognpacific.org	One Outlook Web	205.147.16.190	0		notApplied
2/25/2026, 9:59:52.798 PM	m.smith@lognpacific.org	One Outlook Web	205.147.16.190	0		notApplied
2/25/2026, 9:55:15.212 PM	m.smith@lognpacific.org	One Outlook Web	205.147.16.190	50140	This error occurred due to 'Kee...	notApplied
2/25/2026, 9:54:55.422 PM	m.smith@lognpacific.org	One Outlook Web	205.147.16.190	50140	This occurred due to 'Keep me ...	notApplied

Figure 15 — LAW-Cyber-Range: ConditionalAccessStatus = notApplied across all attacker sessions

Q25 — MFA Fatigue MITRE ID (100 pts) & Q27 — Credential Source (100 pts)

Q25: MFA Fatigue maps to T1621 (Multi-Factor Authentication Request Generation). Q27: Scattered Spider purchases credentials from Infostealer marketplace logs — malware that harvests saved passwords, session tokens, and browser data from infected machines.



Q25 — MITRE T1621: Correct | Q27 — Source: Infostealer: Correct

Q28 — Immediate Containment (75 pts) & Q29 — Threat Actor Attribution (100 pts)

Q28: With the attacker holding a valid session and inbox rules active, the single most critical action is 'Revoke sessions' via Azure AD — immediately invalidates the stolen token. Q29: All TTPs confirm Scattered Spider attribution.

Q28 — Containment: Revoke Sessions: Correct | Q29 — Threat Actor: Scattered Spider: Correct

7. MITRE ATT&CK Mapping

Tactic	ID	Technique	Evidence
Initial Access	T1566.002	Spearphishing Link	AiTM phishing reverse-proxy link
Credential Access	T1555	Password Stores	Infostealer pre-harvested Mark's credentials
Credential Access	T1539	Steal Web Session	Token captured post-MFA via AiTM proxy

Tactic	ID	Technique	Evidence
		Cookie	
Credential Access	T1621	MFA Request Generation	3 fatigue push attempts before bypass
Defense Evasion	T1078	Valid Accounts	Legitimate stolen session replayed
Defense Evasion	T1556.006	MFA Bypass	Token replay — no MFA satisfied independently
Defense Evasion	T1090	Proxy	Netherlands VPN/proxy — 205.147.16.190
Persistence	T1137.005	Outlook Rules	Rules '.' (forward) and '..' (delete)
Collection	T1114.002	Remote Email Collection	MailItemsAccessed at scale
Collection	T1213.002	SharePoint	SharePoint Online PageViewed/ListCreated
Collection	T1213	Info Repositories	OneDrive FileAccessed 22:07:16 UTC
Lateral Movement	T1534	Internal Spearphishing	BEC thread hijack to j.reynolds (Intra-org)
Exfiltration	T1567	Exfil over Web Service	Mail forwarded to duck.com; M365 API access
Impact	T1657	Financial Theft	Wire fraud — Urgent Wire Transfer Request

8. Impact Assessment

CONFIDENTIALITY	INTEGRITY	AVAILABILITY
CRITICAL	HIGH	LOW
Email, OneDrive & SharePoint exposed. Financial data forwarded to insights@duck.com	BEC wire fraud sent. Two covert inbox rules manipulated mail flow and suppressed security alerts	No service disruption. M365 remained operational throughout

9. Recommendations

Immediate (0–24 Hours)

- Revoke all active sessions for m.smith@lognpacific.org via Azure AD → Revoke Sign-in Sessions
- Force password reset on the compromised account
- Delete both malicious inbox rules ('.' and '..') from Mark's mailbox immediately
- Block 205.147.16.190 at the perimeter firewall and via Azure AD Named Locations (Conditional Access)
- Block insights@duck.com at the email gateway — add to blocked sender list
- Contact j.reynolds@lognpacific.org urgently — confirm no wire transfer was actioned on the fraudulent request
- Initiate data impact assessment for all OneDrive and SharePoint content accessed from the attacker IP

Short-Term (1–7 Days)

- Deploy Phishing-Resistant MFA (FIDO2 hardware key / Windows Hello for Business) — eliminates AiTM token-replay attack surface entirely
- Enforce Conditional Access requiring compliant, managed devices for M365 access — ConditionalAccessStatus was notApplied; this is the primary gap to close immediately
- Enable Continuous Access Evaluation (CAE) — near-real-time session token revocation on location/IP anomaly
- Search SigninLogs for 205.147.16.190 across ALL UPNs to identify any other compromised accounts from the same campaign
- Review all CloudAppEvents and EmailEvents for the attack window to confirm full exfiltration and BEC scope

Strategic / Long-Term

- Deploy Microsoft Entra ID Protection with risk-based Conditional Access — auto-blocks sign-ins with token replay anomaly scores
- Enable Defender for Cloud Apps anomaly policies: impossible travel, mass download, infrequent country authentication
- Implement inbox rule monitoring alerts: New-InboxRule where ForwardTo is external, rule name is a single/double character, or StopProcessingRules is True
- Implement BEC controls: mandatory out-of-band verification for any wire transfer or banking detail change regardless of internal sender
- Monitor endpoints for Infostealer indicators — credential theft precedes AiTM in the Scattered Spider kill chain; early detection here breaks the chain
- Conduct targeted Scattered Spider awareness training — AiTM pages are visually indistinguishable from legitimate Microsoft login pages

10. Conclusion

This threat hunt by Vishvdeep Bal on the Log(N) Pacific Cyber Range successfully reconstructed the complete Scattered Spider kill chain: from Infostealer credential theft, through AiTM MFA bypass, 30+ burst post-auth data accesses, dual inbox rule persistence, OneDrive/SharePoint exfiltration, and Business Email Compromise wire fraud. 28 of 29 challenges were solved, scoring 2410 points and placing 71st on the global leaderboard.

The single most actionable finding from this investigation is the ConditionalAccessStatus: notApplied gap. Enforcing a Conditional Access policy requiring compliant, managed devices would have blocked the attacker's Linux/Firefox 147.0 session replay entirely — regardless of whether their session token was valid. This one control breaks the AiTM kill chain at the point of access rather than at the MFA gate.

The complete attack was correlated through a single AAD Session ID (00225cfa-a0ff-fb46-a079-5d152fcdf72a), demonstrating the forensic value of session-level correlation across SigninLogs, CloudAppEvents, and EmailEvents in Microsoft Sentinel. KQL-based hunting in the LAW-Cyber-Range workspace provided definitive, evidence-grounded findings at every stage of the kill chain.

Report by Vishvdeep Bal • vishvdeepbal.infosec@gmail.com • Log(N) Pacific Cyber Range • Case IR-2026-0225-001 • April 17, 2026